

网络安全新技术——

DGA

北京邮电大学

郑康锋

kfzheng@bupt.edu.cn

参考文献: <https://www.cnblogs.com/Hardworking666/p/17374796.html>
<https://www.secrss.com/articles/14369>

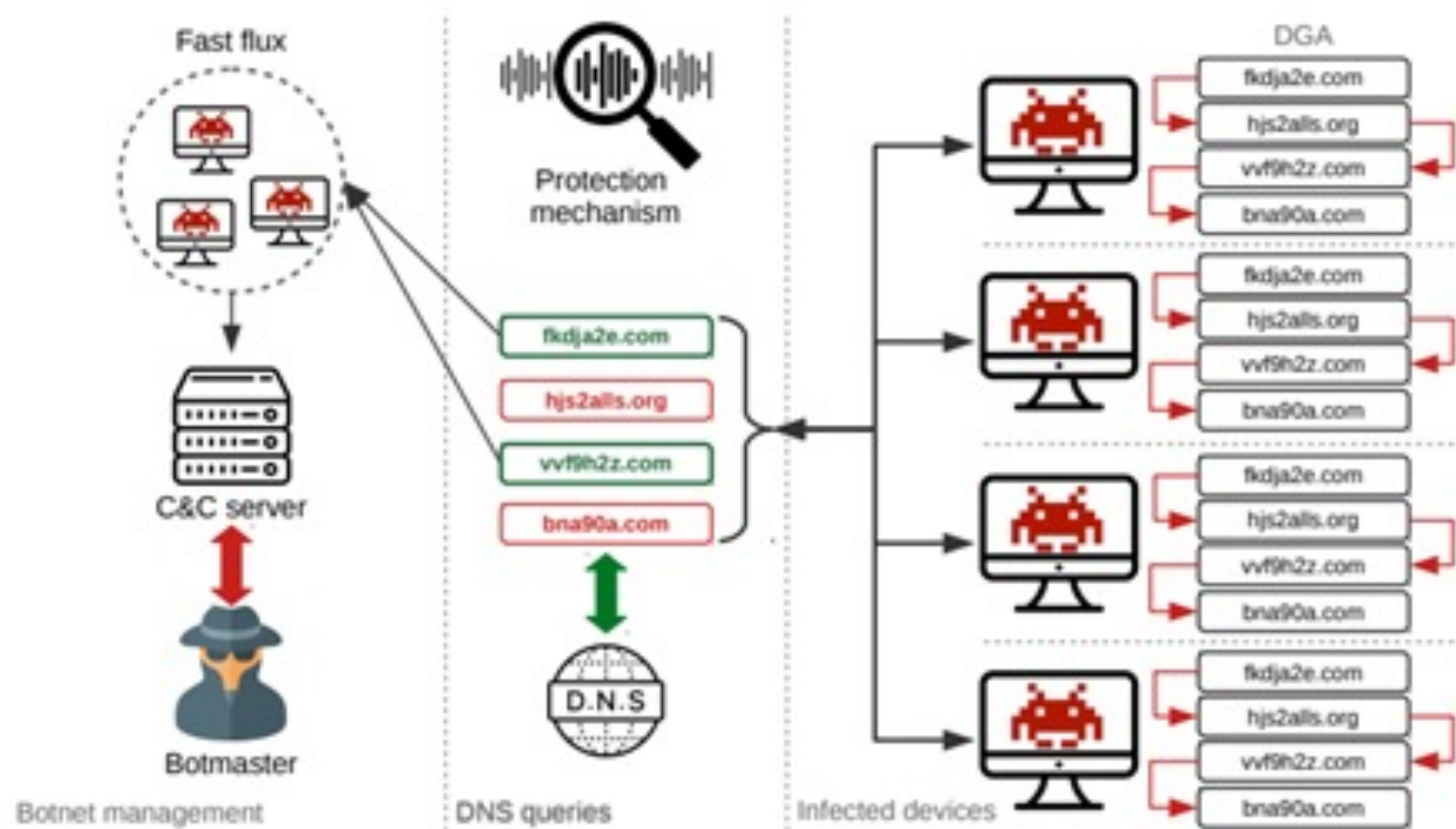
DGA

- DGA (Domain Generation Algorithm, 域名生成算法) 是一种利用随机字符 来生成 C&C (Command and Control, 命令与控制) 域名, 从而逃避域名黑名单检测 的技术手段。
- 攻击者利用**DGA**产生恶意域名后, 选择部分域名进行注册并指向**C&C**服务器。
- 当受害者运行恶意程序后, 主机将通过恶意域名连接至**C&C**服务器, 攻击者即可远程操控主机。
- 在红队攻击和渗透测试中, 好的**DGA**域名是攻击准备的一部分。

最新的技术报告估计, 恶意**AGD**域名数量约占域名总数的**9.9%**, 其中**1/5**属于基于**DGA**的僵尸网络 (约占所有注册域名的**1.8%**) 。

DGA

- 攻击者与恶意软件运行同一套**DGA**算法，生成相同的备选域名列表，发动攻击时选择其中少量进行注册建立通信。
 - 对注册的域名应用速变IP技术，快速变换IP，从而域名和IP都可以进行快速变化。
- ## IP FLUX
- 传统基于黑名单的防护手段无法起作用：黑名单的更新速度远远赶不上**DGA**域名的生成速度；防御者必须阻断所有的**DGA**域名才能阻断C2通信。



DGA分类

- DGA算法由两部分构成，种子（算法输入）和算法，可以根据种子和算法对DGA域名进行分类，DGA域名可以表示为AGD（Algorithmically-Generated Domains）。
- **按照种子进行分类**
 - **1.基于时间的种子（Time dependence）**。DGA算法将会使用时间信息作为输入，如：感染主机的系统时间，http响应的时间等。
 - **2.是否具有确定性（Determinism）**。主流的DGA算法的输入是确定的，因此AGD可以被提前计算，但是也有一些DGA算法的输入是不确定的，如：Bedep[4]以欧洲中央银行每天发布的外汇参考汇率作为种子，Torpig[5]用twitter的关键词作为种子，只有在确定时间窗口内注册域名才能生效。

DGA分类

根据种子的分类方法，DGA域名可以分为以下4类：

- **1.TID**（**time-independent and deterministic**），与时间不相关，可确定；
- **2.TDD**（**time-dependent and deterministic**），与时间相关，可确定；
- **3.TDN**（**time-dependent and non-deterministic**），与时间相关，不可确定；
- **4.TIN**（**time-independent and non-deterministic**），与时间不相关，不可确定；

DGA分类

按照生成算法进行分类

- 1.基于算术。**该类型算法会生成一组可用ASCII编码表示的值，从而构成DGA域名，流行度最高。
- 2.基于哈希。**用哈希值的16进制表示产生DGA域名，被使用的哈希算法常有：MD5，SHA256。
- 3.基于词典。**该方式会从专有词典中挑选单词进行组合，减少域名字符上的随机性，迷惑性更强，字典内嵌在恶意程序中或者从公有服务中提取。
- 4.基于排列组合。**对一个初始域名进行字符上的排列组合。

根据种子和生成算法的不同，DGA域名可以选择不同种子类型和算法类型的组合方式，因此最终DGA域名的生成形式多样性高。

DGA域名存活时间

- **Plohmann Daniel**等人对**43**个恶意软件家族做逆向分析，实现了**DGA**算法并对超过**1**亿个**DGA**域名做分析，结合**WHOIS**信息，统计出了不同**DGA**家族域名存活时间的分布。
- 总结来说**DGA**域名的存活时间一般较短，**大部分域名的存活时间为1-7天**，因此**DGA**域名这种存活时间短的特性对防守方的检测实时性提出了更高的要求，防守方需要在尽量短的时间内对检测出**DGA**域名，并作出相应的处置措施，才能有效降低风险。

DGA域名举例

- DGA的使用非常广泛，目前已知的DGA家族有40多个。
- 右表列举了4个DGA家族的TLD（顶级域）、SLD（二级域）和样例。

antavmu	TLD	Com、net、org、duckdns.org
	SLD	固定长度为8，16进制表示，每天生成16个域名
	举例	2c2b3749.com 4933c012.com c92e3378.duckdns.org
banjori	TLD	与种子域名相同
	SLD	只改变种子域名的前4个字符，总共2196或者15372个域名
	举例	earnestnessbiophysicalohax.com kwtoestnessbiophysicalohax.com rvcxestnessbiophysicalohax.com
ccleaner	TLD	com
	SLD	长度为11-13，a-f和0-9的组合，每月1个
	举例	ab1145b758c30.com ab890e964c34.com ab3d685a0c37.com
suppobox_v1	TLD	Net
	SLD	词典中两个词的组合，每月254个
	举例	sharmainewestbrook.net (from wordlist 3) tablethirteen.net (from wordlist 2) childrencatch.net (from wordlist 1)

DGA检测

DGA域名检测大致可以分为以下两种：基于文本分析、基于行为分析。

- 基于文本分析：
 - 通过分析DGA域名与正常域名之间字符分布的差异，对IP产生的域名进行批量分类；
 - 通过LSTM等算法分析DGA域名与正常域名之间的差异，可以判定每个域名是否为DGA域名。
- 基于行为分析：
 - 对同一主机产生的NXDomain进行聚类 and 分类，可以发现感染主机，进一步发现C2域名；
 - 将检测问题转为图的推理问题，从代理日志构造主机与域名之间的关系图，用一些真实信息作为种子作为图的输入，然后使用信念传播算法估计域名为恶意的边缘概率。

DGA检测

基于注册状态进行检测

- 基于注册状态进行检测主要是通过域名在商业平台注册的情况评判，例如以下指标：
 - • 注册时间不超过一周的新域名
 - • 通配符域名
 - • 二级域名不在Alexa top 10K
 - • .xyz,.biz,.info等审核不严的TLD
- 绕过检测的主要方法有：
 - • 在使用域名之前保持较久的注册时间
 - • 避免在使用ccTLD中的一级域名
 - • 使用云计算服务商的cname域名

DGA检测

基于威胁情报进行检测

- 通过威胁情报平台和DGA数据集进行检测主要用于检测已知的DGA域名，一些常见的的数据集和威胁情报平台如下：
 - 306netlab dga 360dga数据集
 - virustotal.com virustotal平台
 - x.threatboot.com 微步威胁情报平台
 - ti.360.cn 360威胁情报平台
 - tj-un.com 天际友盟平台
- 绕过检测的主要方法有：
 - 启用whois隐私保护
 - 使用CDN保护域名
 - 注册已过期域名
 - 在实际使用前将ip解析到安全站点上
 - 使用之前提交到威胁情报平台做检测，加入白名单

谢谢！